



Non-Functional Requirements (NFR)

TASCO Insurance × VETC Growth Platform — Business & Product

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

- 0. Conventions
- 1. Performance
- 2. Scalability
- 3. Availability and resilience
- 4. Security (OWASP ASVS 4.0 Level 2)
- 5. Privacy and data protection
- 6. Accessibility and usability
- 7. Localisation
- 8. Maintainability and quality
- 9. Observability
- 10. Disaster recovery and backup
- 11. Portability and deployment
- 12. Auditability
- 13. Configurability
- 14. Data retention
- 15. Compliance-by-design (cross-cutting)

Document	Version	Date	Owner	Status
Non-Functional Requirements	1.0	07 October 2026	iorta TechNXT — Solution Architecture	Issued for submission

TASCO Insurance × VETC Motor Insurance Growth Platform · prepared by iorta TechNXT

0. Conventions

- IDs are `NFR-nnn`. Each NFR has a **measurable target**, a **verification method** and its **current support in the codebase** as of 07 October 2026 (*Built, Partial* or *Planned*). References such as "doc 05" point to the companion documents listed in the Business and Product Documentation index (00-index.pdf).
- Targets are **proposed**. They must be agreed with TASCO and VETC IT in Phase 0 and baselined in a full-scale performance test. The current load smoke test (`test/perf/load.js`, one process, 25 concurrent clients) achieves about 337 requests/s with p95 ≈ 103 ms and 0% errors.
- Current quality baseline: 238 automated tests (235 pass, 0 fail, 3 manual/roadmap scenarios), coverage 99.5% lines, 91.6% branches and 97.2% functions, ESLint 0 errors.
- Sizing reference: **6,000,000 vehicles** (VETC car base, from the brief). Workload assumptions are labelled `[W-n]`.

0.1 Workload model (assumptions)

ID	Assumption	Value
W-1	Golden profiles	6 M (12 M source records at about 2 per vehicle)
W-2	Leads re-scored nightly (full) / on events (partial)	6 M per night / ≤ 50k per hour
W-3	Touchpoints due per day at peak (month-end and Tết)	300k
W-4	Concurrent staff users	300 (telesales 200, other 100)
W-5	Customer app sessions at peak (push campaign)	2,000 requests/s for 15 minutes
W-6	Concurrent bot calls (vendor side)	200
W-7	Partner API peak	50 requests/s

1. Performance

ID	Requirement	Target	Verification	Support
NFR-001	API latency, read endpoints (leads list, customer 360, home, certificate verify)	p95 ≤ 300 ms, p99 ≤ 800 ms at W-4 / W-5 load	<code>test/perf/load.js</code> ; histogram <code>http_request_duration_seconds</code>	Partial (metrics and load smoke test built; full-scale test planned)
NFR-002	API latency, quote	p95 ≤ 500 ms	<code>test/perf/load.js</code> (includes <code>POST /api/quotes</code>)	Partial (smoke level only)
NFR-003	Purchase (pay + issue) end-to-end excluding upstream latency	p95 ≤ 1.5 s; upstream timeouts 5 s with 2 retries	Load test; circuit-breaker config	Built (<code>src/shared/resilience.js</code> defaults: timeout 5,000 ms, retries 2)

ID	Requirement	Target	Verification	Support
NFR-004	Bot dialogue turn processing (excluding ASR and TTS)	$p95 \leq 150$ ms per turn	Unit benchmark on <code>voicebot.js</code>	Planned
NFR-005	Ingestion throughput	$\geq 2,000$ records/s per worker; 12 M records rebuilt in ≤ 4 h with 4 workers	Batch benchmark	Partial (incremental, chunked rebuild of 500 plates)
NFR-006	Lead recompute	Full 6 M recompute in ≤ 3 h nightly; event-driven partial recompute visible within ≤ 60 s	Job timings in <code>job_runs</code>	Partial (paged by 1,000; parallel workers planned)
NFR-007	Journey run	300k due touchpoints executed within the 08:00–20:00 contact window in ≤ 2 h	<code>journeys.run</code> audit summary	Planned (sharding)
NFR-008	Rule change propagation	Active rules converge on all replicas in ≤ 15 s after approval	<code>rulesService</code> cache TTL 15 s plus <code>rules.activated</code> event	Built

2. Scalability

ID	Requirement	Target	Verification	Support
NFR-009	Horizontal scaling of the API tier	Stateless replicas behind a load balancer; HPA scales 3 → 20 pods at 65% CPU (<code>deploy/k8s/40-hpa-pdb.yaml</code>)	K8s HPA test	Partial (stateless; shared logout-revocation and rate-limit store planned, E-15)
NFR-010	Data volume	6 M profiles, 12 M source records, 50 M messages per year, without query-plan regressions (all filters use indexed columns)	<code>test/pg/postgres.test.js</code> (parameterised filters); EXPLAIN review in the performance test	Built (filters restricted to declared indexed columns: <code>schema.js</code> , <code>query.js</code>)
NFR-011	Background work scales out	Outbox relay safe to run on N replicas (<code>SKIP LOCKED</code>), at-least-once delivery, idempotent handlers, maximum 5 attempts	<code>test/pg/postgres.test.js</code> (exclusive claims), <code>test/unit/stores.test.js</code>	Built (<code>outboxEventBus.js</code>)
NFR-012	Event streaming readiness	The outbox can forward to Kafka or Pub/Sub without changing publishers	Design review	Planned

3. Availability and resilience

ID	Requirement	Target (SLO)	Verification	Support
NFR-013	Customer-facing purchase path (/api/customer/*, /api/partner/v1/*, certificate verify)	99.9% monthly (≤ 43.8 min downtime)	Uptime probe on /health/ready and synthetic purchase	Partial
NFR-014	Staff console and APIs	99.5% monthly, business hours 07:00–21:00 ICT	Uptime probe	Partial
NFR-015	Graceful degradation	Failure of one integration (wallet, core, ZNS, SMS, push, voice) affects only that feature. Circuit opens after 5 failures and half-opens after 30 s.	Chaos test; /api/ops/status circuit state	Built
NFR-016	No double charge	0 duplicate debits under retries or concurrent taps (idempotency key on order and wallet; atomic quote claim)	test/integration/sales.test.js, test/security/security.test.js	Built
NFR-017	Compensation	100% of issuance failures after payment refunded (issued lines cancelled) or flagged as compensation_failed; reconciliation finds 0 unexplained mismatches daily	Reconciliation job report; test/integration/sales.test.js	Built

4. Security (OWASP ASVS 4.0 Level 2)

ID	Requirement	Target	Verification	Support
NFR-018	ASVS L2 compliance across V1–V14	0 open High or Critical findings at go-live; annual third-party penetration test	test/security/security.test.js; CI SAST (CodeQL), DAST baseline (OWASP ZAP), image scan (Trivy); external pentest	Partial (external pentest pending)
NFR-019	Authentication (ASVS V2)	Passwords 12–128 characters, hashed with bcrypt; lockout after 5 failures (password or code) for 15 minutes; TOTP MFA mandatory for privileged roles, self-enrolled, codes not reusable; login rate limit 10/min per IP	test/security/security.test.js, test/integration/governance.test.js	Built
NFR-020	Session management (ASVS V3)	Access token TTL ≤ 30 min; logout revocation effective across all replicas	test/security/security.test.js	Partial (password, role, status and region changes revoke tokens on all replicas; logout revocation per replica, E-15)
NFR-021	Access control (ASVS V4)	Deny by default; RBAC + ABAC on every route; partner scope = own quotes and policies; customer scope = own vehicle; 0 IDOR findings	test/security/security.test.js	Built (partner key scopes enforced; malformed path parameters return 400)

ID	Requirement	Target	Verification	Support
NFR-022	Input validation (ASVS V5)	Allow-list schemas on every body and query (types, lengths, enums, patterns); body ≤ 1 MB; parameterised SQL only; only declared columns filterable	test/security/security.test.js (injection and hostile inputs)	Built (validation.js, routes.js schemas, query.js)
NFR-023	Cryptography (ASVS V6)	PII encrypted at rest with AES-256-GCM, with key rotation via key IDs (DATA_KEYS, DATA_KEY_ACTIVE); HMAC blind index for phone search; API keys stored as SHA-256; TLS 1.2+ in transit; HSTS in production	Config review	Built
NFR-024	HTTP security (ASVS V14)	Strict CSP (default-src 'self', no inline script), X-Frame-Options: DENY, nosniff, Referrer-Policy: no-referrer, CORS allow-list, global rate limit 300 req/min; client IP from the right-most trusted proxy hop (TRUST_PROXY_HOPS)	test/security/security.test.js	Built (security.js)
NFR-025	Secrets	No secrets in code; *_FILE convention for K8s, Docker or Vault secrets; production refuses to boot with missing secrets, without DATABASE_URL or with demo mode on; optional METRICS_TOKEN protects /metrics	test/unit/platform.test.js	Built (config.js)
NFR-026	Dependency hygiene	npm audit --omit=dev --audit-level=high passes in CI; minimal runtime dependencies (currently only pg)	CI (.github/workflows/ci.yml: npm audit, dependency review, secret scan, SBOM)	Built
NFR-027	Voice-channel fraud resistance	The bot never requests an OTP, card or payment; plate verified before any personal data is disclosed; plate and phone masked in summaries	Script review; voicebot unit tests	Built

5. Privacy and data protection

Legal basis to confirm with TASCO legal: the Personal Data Protection Law **91/2025/QH15** (effective 2026), **Decree 13/2023/ND-CP** on personal data protection, **Decree 91/2020/ND-CP** on spam messages and calls, the Law on Insurance Business **08/2022/QH15**, and any data-localisation obligations under the Cybersecurity Law and its implementing decree. The controls below are conservative engineering defaults, **not legal advice**.

ID	Requirement	Target	Verification	Support
NFR-028	Consent by purpose and channel	Marketing and call consent stored per profile; enforced before every marketing message and call; changes audited and honoured within ≤ 1 minute	Integration tests on canContact	Built
NFR-029	Data-subject rights	Access (self-service download and staff export) and erasure by anonymisation, completed within ≤ 72 h of a verified request. Legal-retention exceptions documented.	test/integration/governance.test.js, test/functional (US-060, US-061)	Built (72-hour handling is an operational process)
NFR-030	Data residency	Personal data of Vietnamese data subjects stored and processed in a hosting location approved by TASCO legal (a Vietnam region if required). A cross-border transfer impact assessment is filed if any processor is offshore (for example a voice-AI vendor).	Architecture review	Planned (confirm with TASCO legal)
NFR-031	Data minimisation and masking	Staff without <code>profile:read_pii</code> never see full name or phone; handoffs carry masked phone; the public certificate check shows a masked plate and no PII	Security tests	Built
NFR-032	Processing records and DPIA	A Data Protection Impact Assessment and processing register maintained for each purpose (renewal, conquest, bot calls, partner sharing)	Compliance sign-off	Planned
NFR-033	Synthetic data outside production	Non-production environments use synthetic data only (<code>syntheticVetSource.js</code>) or irreversibly masked extracts	Environment audit	Built (synthetic generator)

6. Accessibility and usability

ID	Requirement	Target	Verification	Support
NFR-034	Accessibility	WCAG 2.2 Level AA for the staff console and customer app: contrast $\geq 4.5:1$, full keyboard operation, visible focus, target size $\geq 24 \times 24$ px, labelled form fields, <code>prefers-reduced-motion</code> respected	axe-core automated scan (0 serious) plus manual screen-reader check (TalkBack and VoiceOver)	Partial (UI built; formal audit planned)
NFR-035	Customer task efficiency	Renew from a reminder in ≤ 3 taps after opening the link; renewal completed in ≤ 60 s median	Usability test ($n \geq 8$ per segment); adoption target in <code>insightsService</code>	Planned
NFR-036	Staff task efficiency	Agent sees the next lead and talking points in ≤ 2 clicks from home; handoff first contact within 2 business hours	Usability test; handoff timestamps	Planned
NFR-037	Explainability	Every score, NBA and benefit shown to staff carries a human-readable reason	UI review	Built (API: <code>reasons[]</code> , <code>nextBestAction.reason</code> , <code>benefits[].why</code>)

ID	Requirement	Target	Verification	Support
NFR-038	Help	Contextual help drawer on every console screen, in Vietnamese and English	UI review	Partial (help drawer built in English; Vietnamese help text planned)

7. Localisation

ID	Requirement	Target	Verification	Support
NFR-039	Bilingual UI	Vietnamese (default for customers) and English, switchable at runtime. 100% of UI strings externalised.	Pseudo-localisation test	Built (runtime toggle, <code>public/js/shared/i18n.js</code>); pseudo-localisation test planned
NFR-040	Vietnamese conventions	Dates dd/mm/yyyy; currency vi-VN formatting (for example 480.700 đ); full diacritics; accent-insensitive search and matching	Unit tests (<code>viDate</code> , <code>stripDiacritics</code>)	Built (backend)
NFR-041	Customer copy in Vietnamese reviewed by TASCO	100% of templates and bot lines approved through maker-checker before activation	Rules audit trail	Built (workflow)

8. Maintainability and quality

ID	Requirement	Target	Verification	Support
NFR-042	Automated test coverage	Lines ≥ 80%, functions ≥ 80%, branches ≥ 70% (excluding CLI, server bootstrap and the PG adapter, which has its own suite)	<code>npm run test:coverage</code> (thresholds in <code>package.json</code> , gated in CI)	Built (99.5% lines, 91.6% branches, 97.2% functions)
NFR-043	Static analysis	ESLint 9 with 0 errors on every commit	<code>npm run lint</code> in CI	Built (<code>eslint.config.js</code> ; 0 errors)
NFR-044	Architecture	Hexagonal: pure domain (<code>src/domain</code>), application services, adapters behind ports; no business thresholds in domain code	Code review; dependency rule check	Built (remaining literals listed in E-05)
NFR-045	API-first	100% of routes described in OpenAPI 3, generated from the route table (<code>npm run job openapi</code>)	CI diff on <code>docs/api/openapi.json</code>	Built
NFR-046	Schema governance	DB migrations match the collection registry; applied migrations are never edited; migrations take an advisory lock	<code>test/unit/platform.test.js</code> (schema drift guard), <code>test/pg/postgres.test.js</code>	Built (registry, DDL generator, migrations 001 and 002)

9. Observability

ID	Requirement	Target	Verification	Support
NFR-047	Metrics	Prometheus /metrics: request rate, errors and duration by route; quotes_total, orders_completed_total, messages_total, voice_calls_total, integration_calls_total, short-circuits	Dashboard review	Built
NFR-048	Logs	Structured JSON logs with request ID (X-Request-Id propagated); no PII in logs	Log review; security test	Built
NFR-049	Alerting	Alerts on SLO burn rate, circuit open > 5 min, outbox backlog > 10k or age > 10 min, failed jobs, audit-chain verification failure	Alert runbook test	Planned
NFR-050	Business observability	Growth, economics, adoption and governance dashboards refreshed ≤ 5 min	FR-100 – FR-102	Built (on demand)

10. Disaster recovery and backup

ID	Requirement	Target	Verification	Support
NFR-051	Recovery point objective	RPO ≤ 5 minutes (PostgreSQL PITR with continuous WAL archiving)	Quarterly restore drill	Planned (infrastructure)
NFR-052	Recovery time objective	RTO ≤ 1 hour for the purchase path; ≤ 4 hours for the full platform	Annual DR exercise	Planned
NFR-053	Backups	Daily full backups kept 35 days and monthly backups kept 13 months, encrypted, in a separate account or region approved under NFR-030	Backup report	Planned
NFR-054	Audit integrity after restore	Audit hash chain verifies (GET /api/audit/verify) after every restore	DR runbook	Built (verify)

11. Portability and deployment

ID	Requirement	Target	Verification	Support
NFR-055	Runtime	Node.js ≥ 22.12 LTS, PostgreSQL 15+; an in-memory store for demo and tests with identical behaviour (never in production)	CI (test/pg/postgres.test.js against PostgreSQL)	Built
NFR-056	Packaging	OCI container image (non-root, read-only filesystem, health probes /health/live and /health/ready)	Image scan in CI (Trivy)	Built (Dockerfile runs as the node user, uid 1000; Kubernetes runAsUser: 1000, read-only root filesystem)
NFR-057	Targets	Deployable to Kubernetes (Helm or Kustomize; CronJobs for journeys, recompute, reconcile, retention, relay) and to Railway or a similar PaaS for demo and UAT. Cloud-agnostic, with no proprietary managed services required.	Deployment rehearsal	Built (Kustomize manifests and CronJobs in deploy/k8s; Railway UAT live with PostgreSQL)
NFR-058	Configuration	12-factor: all settings from the environment; secrets via *_FILE	Config review	Built

12. Auditability

ID	Requirement	Target	Verification	Support
NFR-059	Completeness	100% of state-changing operations and all PII views audited (FR-097)	Audit coverage test	Built
NFR-060	Immutability	Audit log is append-only (DB triggers reject UPDATE, DELETE and TRUNCATE) and hash-chained; verification runs daily	db/migrations/001_init.sql, 002_integrity_hardening.sql; test/pg/postgres.test.js	Built
NFR-061	Traceability of decisions	Every lead evaluation can be reproduced from the rule version (ID and checksum) and facts in force at the time	Rules snapshot in /api/ops/status	Partial (store rule version on the lead: planned)

13. Configurability

ID	Requirement	Target	Verification	Support
NFR-062	No hardcoded business rules	100% of thresholds, weights, tariffs, rates, journeys, copy, consent policy, commission and retention in rule kinds, changeable by the business through maker-checker without a release	Code review checklist; grep for numeric literals in src/domain and src/application	Partial (service levels moved to rule kind service_levels; E-05 lists the remaining literals)
NFR-063	Safe change	Every rule change validated, simulated (scoring, NBA, journeys, benefits), approved by a second person, versioned and reversible	FR-083 – FR-087	Built
NFR-064	Lead time for business change	≤ 1 business day from request to activation for a rule change	Adoption dashboard target	Built (workflow)

14. Data retention

ID	Requirement	Target	Verification	Support
NFR-065	Retention schedule	Source records 365 days (delete); profiles 1,825 days after last activity with no active policy (anonymise); voice recordings and transcripts 180 days (delete); messages 365 days (archive); orders and certificates 3,650 days (archive, financial records); audit log 3,650 days (archive, never deleted early)	Retention job report	Partial (deletes built for source records and voice sessions; archival pipeline planned, E-09)
NFR-066	Legal hold	A legal hold flag suspends deletion for named entities	Retention test	Planned

15. Compliance-by-design (cross-cutting)

ID	Requirement	Target	Verification	Support
NFR-067	No discount language reaches customers	0 customer messages containing copy_guard phrases (validated at save and blocked at send)	messageStatus.blocked = 0 after go-live	Built

ID	Requirement	Target	Verification	Support
NFR-068	Contact hygiene	0 marketing contacts outside 08:00–20:00 ICT or above caps	Message log analysis	Built (journeys, triggers and voice campaigns)
NFR-069	Commission caps	0 commission lines above the statutory cap	Validator plus statement audit	Built